NexusGov — Documento de Requisitos de Software (SRS) e Metodologia

Plataforma de Auditoria Forense por Grafos e Triagem Estatística de Contratações Públicas

Versão 1.0 (rascunho para validação) · Metodologia de desenvolvimento: Spec-Driven Development (SDD)

1. Introdução

1.1 Propósito

Este documento especifica os requisitos funcionais, não funcionais, metodológicos, de arquitetura e de aceite do **NexusGov**, uma infraestrutura aberta e auditável que cruza dados do Portal Nacional de Contratações Públicas (PNCP) com a base pública de CNPJs da Receita Federal para **triar** indícios de concorrência fictícia, fracionamento de despesa e empresas recém-criadas vencedoras de certames relevantes.

O documento serve como contrato entre a visão do produto e a implementação, e como base para a matriz de rastreabilidade (diretório `spec/`) e para o registro de software.

1.2 Escopo

Dentro do escopo:

- Ingestão, normalização e armazenamento de dados do PNCP, do cadastro de CNPJs (Empresas, Estabelecimentos, Sócios, CNAEs) e das tabelas de municípios do IBGE.
- Construção de grafo empresa–sócio–licitação e cálculo de métricas de rede.
- Testes estatísticos (Lei de Benford) e detecção de janelas temporais de fracionamento.
- Cálculo do **Índice de Exposição a Anomalias (IEA)** com evidência rastreável.
- API REST, controle de acesso por papéis (RBAC), relatórios em PDF, exportações em CSV/Parquet e visualizador interativo de redes.

Fora do escopo (versão 1.0):

- Emissão de juízo de mérito, acusação ou conclusão de ilícito (vedado pela salvaguarda metodológica, seção 4.5).
- Integração com sistemas de tramitação processual de tribunais de contas ou ministérios públicos.
- Dados sigilosos, fiscais protegidos ou obtidos fora de fontes oficiais abertas.

- Aprendizado de máquina supervisionado (não há base rotulada confiável; poderá ser avaliado em versões futuras).

1.3 Público-alvo e partes interessadas

Perfil	Necessidade principal
Auditor de controle interno/externo	Priorizar processos para análise com evidência verificável
Gestor público (prefeituras, câmaras)	Autoavaliar a própria carteira de contratações
Cidadão / jornalista / pesquisador	Explorar redes e indicadores de forma transparente
Administrador da plataforma	Operar ingestão, usuários, parâmetros e auditoria
Pesquisador (Lattes / registro de software)	Reprodutibilidade científica e documentação metodológica

1.4 Definições e siglas

- **PNCP:** Portal Nacional de Contratações Públicas (Lei 14.133/2021).
- **QSA:** Quadro de Sócios e Administradores.
- **IEA:** Índice de Exposição a Anomalias.
- **CATMAT/CATSER:** Catálogos de materiais e serviços.
- **Cover bidding:** concorrência fictícia (propostas de cobertura).
- **Pop-up vendor:** empresa recém-criada que vence certames relevantes.
- **SDD:** Spec-Driven Development.
- **MAD:** Mean Absolute Deviation (métrica de conformidade à Lei de Benford).

2. Contexto legal, ético e de privacidade

Este é o requisito de maior risco do projeto e deve ser tratado como **restrição de projeto**, não como detalhe.

1. **Natureza da saída:** o sistema produz *indícios estatísticos de triagem*, nunca prova de ilícito. Alta exposição significa "merece verificação humana", não "houve fraude".
2. **LGPD (Lei 13.709/2018):** dados do QSA são públicos, mas o CPF de sócios pessoas físicas é divulgado de forma **mascarada** (apenas dígitos centrais). O tratamento deve respeitar finalidade, necessidade e transparência (art. 7º, §§ 3º e 4º). É vedado tentar

reidentificar CPFs completos.

3. **Lei de Acesso à Informação (12.527/2011) e Lei 14.133/2021:** fundamentam o uso de dados abertos e a publicidade das contratações.
4. **Risco de homonímia:** vínculos baseados em nome + CPF parcial podem gerar falsos positivos. Todo vínculo deve carregar um **nível de confiança** e ser exibido como tal.
5. **Parentesco por sobrenome:** sobrenomes comuns geram ruído elevado. Esse vínculo é **opcional, de peso baixo e desativado por padrão** no perfil de produção, e nunca deve ser a única base de um nível "Elevado".
6. **Exposição pública:** relatórios com nomes de pessoas físicas devem trazer aviso metodológico obrigatório e possibilidade de contestação/retificação (RF-REL-05).
7. **Recomendação:** submeter o projeto a parecer jurídico (encarregado de dados/LGPD) antes de qualquer publicação aberta com nomes de pessoas físicas.

3. Visão geral do produto

3.1 Problemas tratados

1. **Concorrência fictícia:** empresas concorrentes em um mesmo certame que compartilham sócios, administradores, telefone, e-mail ou endereço.
2. **Fracionamento de despesa:** dispensas repetidas, para o mesmo fornecedor e objeto, mantidas logo abaixo do teto legal em janelas curtas.
3. **Empresas recém-nascidas:** CNPJs abertos pouco antes de um certame de valor elevado, com capital social incompatível.
4. **Anomalias de preço/valor:** desvios na distribuição de dígitos e em relação a preços de referência.

3.2 Princípios de projeto

- **Auditabilidade:** cada indicador é reproduzível a partir do dado bruto e do hash do payload.
- **Transparência algorítmica:** fórmulas, pesos e limiares documentados e versionados.
- **Parametrização:** tetos legais e limiares nunca são fixados em código; ficam em configuração versionada com vigência (tetos de dispensa são atualizados periodicamente por decreto).
- **Conservadorismo:** na dúvida, o sistema rebaixa o nível de risco e exibe a incerteza.
- **Dados abertos:** exportações em formatos abertos (CSV, Parquet, JSON).

4. Metodologia científica e analítica

4.1 Eixo 1 — Grafos (Empresa–Sócio–Licitação)

Modelo. Grafo heterogêneo com conjunto de nós V = {E, S, L, A}, onde E = empresas, S = sócios/administradores, L = licitações/contratações e A = atributos de contato (endereço normalizado, telefone, e-mail). Arestas:

Aresta	Descrição	Peso base (configurável)
E–S	Vínculo societário direto (CPF/CNPJ parcial + nome normalizado)	1,0 × confiança
E–A	Compartilhamento de endereço, telefone ou e-mail	0,6 a 0,8
E–L	Participação ou adjudicação em licitação	1,0
S–S	Parentesco presumido por sobrenome (opcional)	0,1

Procedimento.

1. Normalização de nomes (caixa, acentos, partículas) e de endereços (logradouro, número, CEP).
2. Projeção do grafo bipartido em um **grafo de coocorrência de empresas** (duas empresas ligadas se compartilham sócio/atributo), preservando o peso.
3. **Detecção de comunidades** pelo algoritmo de Louvain (ou Leiden, preferível por garantir comunidades conectadas), com semente fixa para reprodutibilidade.
4. **Betweenness centrality** (aproximada por amostragem em grafos grandes) para identificar nós-ponte.
5. **Métrica de risco por licitação (RC):** proporção de pares de licitantes da mesma licitação pertencentes à mesma comunidade ou com vínculo direto, ponderada pelo peso das arestas.
6. **Controle de linha de base:** comparar RC com o valor esperado em grafos nulos (modelo de configuração/permutação) para reduzir falsos positivos causados por mercados naturalmente concentrados (ex.: um único município com poucos fornecedores).

4.2 Eixo 2 — Lei de Benford

Hipótese nula: o primeiro dígito significativo d segue P(d) = log10(1 + 1/d), d = 1…9.

Procedimento.

1. Aplicar apenas a conjuntos com **n ≥ 300** valores e amplitude de pelo menos duas ordens de grandeza; abaixo disso, o resultado é marcado como "não aplicável", e não como "conforme".
2. Calcular **qui-quadrado** (8 graus de liberdade) e **MAD de Nigrini** (limiares de conformidade: ≤ 0,006 próximo; 0,006–0,012 aceitável; 0,012–0,015 marginal; > 0,015 não conforme).
3. Aplicar **Kolmogorov-Smirnov** sobre a distribuição da mantissa (log10 do valor módulo 1), que é contínua, em vez de sobre o dígito discreto, para evitar uso incorreto do teste.
4. Aplicar correção de múltiplas comparações (Benjamini-Hochberg) quando vários órgãos/fornecedores forem testados simultaneamente.
5. Reportar o tamanho de efeito (MAD) junto ao p-valor, pois qui-quadrado rejeita facilmente a hipótese nula com amostras muito grandes.

Limitação declarada: valores regulados por tabelas, tetos, preços tabelados ou contratos padronizados desviam de Benford legitimamente. O sistema permite excluir tais categorias (por CATMAT/CATSER) da análise.

4.3 Eixo 3 — Fracionamento (clusterização temporal 1D)

1. Agrupar contratações diretas por (órgão, fornecedor, código de catálogo CATMAT/CATSER ou classe equivalente).
2. Para cada grupo, aplicar **janela deslizante** de 30, 60 e 90 dias (configurável).
3. Sinalizar a janela quando a soma dos valores exceder o teto da modalidade vigente na data, ou quando houver ≥ k contratações (padrão k = 3) cada uma entre 80% e 100% do teto.
4. Opcionalmente, aplicar clusterização 1D (ex.: DBSCAN sobre datas) para detectar rajadas de contratação.
5. Os tetos legais são lidos da tabela de parâmetros com vigência (RF-CFG-02), nunca de constantes no código.

4.4 Eixo 4 — Empresas recém-criadas (pop-up vendors)

Indicadores: idade do CNPJ na data de abertura do certame (dias), razão valor contratado / capital social, compatibilidade entre CNAE principal e objeto, distância geográfica entre sede do fornecedor e órgão (via IBGE) e porte declarado.

4.5 Salvaguarda metodológica inviolável e Índice de Exposição a Anomalias (IEA)

O IEA é um escore de 0 a 100 por contratação, combinando sinais normalizados:

$$IEA = 100 \times \Sigma (w_i \cdot s_i \cdot c_i) / \Sigma w_i$$

em que $s_i \in [0,1]$ é o sinal i (rede, Benford, fracionamento, idade/capital, geografia), w_i o peso versionado e $c_i \in [0,1]$ a confiança do dado subjacente. Níveis padrão: **Baixo** (< 30), **Médio** (30 a 60), **Elevado** (> 60), com limiares configuráveis e calibrados por análise de distribuição empírica.

Regras invioláveis:

- **SG-01:** a interface, os relatórios e a API nunca usam termos como "fraude", "crime", "culpado" ou "conluio comprovado"; usam "indício", "exposição" e "sinal".
- **SG-02:** todo nível "Médio" ou "Elevado" exibe os sinais que o compõem e suas evidências.
- **SG-03:** todo relatório contém aviso metodológico e versão do modelo/pesos.
- **SG-04:** nível "Elevado" exige ao menos **dois sinais independentes** de eixos distintos.
- **SG-05:** sinais baseados apenas em homonímia ou sobrenome não elevam o nível acima de "Médio".

4.6 Evidência forense rastreável

Cada achado armazena: URL e identificador do recurso no PNCP, **hash SHA-256 do payload bruto**, data/hora da coleta (UTC), trecho do dado que sustenta o sinal, versão do dataset da Receita (competência mensal), versão do código e dos pesos. A recomputação a partir dos mesmos insumos deve produzir resultado idêntico (determinismo).

4.7 Validação científica

- **Dados sintéticos:** gerador de cenários com cartéis, fracionamento e empresas de fachada injetados, para medir precisão, revocação e F1 dos detectores.
- **Casos de referência públicos:** avaliação retrospectiva em casos já julgados ou divulgados por órgãos de controle, usados somente para validação.
- **Análise de sensibilidade** dos pesos e limiares.
- **Reprodutibilidade:** ambiente containerizado, sementes fixas, dados versionados por competência e relatório de experimentos.

5. Requisitos funcionais

Prioridade: **M** = Must, **S** = Should, **C** = Could.

5.1 Ingestão e dados (ING)

ID	Requisito	Prior.
RF-ING-01	Coletar contratações, itens, atas, contratos e resultados da API REST do PNCP com paginação, retentativas com backoff exponencial e respeito aos limites de taxa	M
RF-ING-02	Armazenar o payload bruto imutável com hash SHA-256 e carimbo de coleta	M
RF-ING-03	Importar os dumps mensais da Receita (Empresas, Estabelecimentos, Sócios, CNAEs, Municípios, Naturezas) por processamento em blocos	M
RF-ING-04	Converter CSV para Parquet particionado por competência e UF, com esquema validado	M
RF-ING-05	Filtrar o universo de CNPJs para fornecedores presentes no PNCP, preservando a base completa em armazenamento frio	S
RF-ING-06	Carga incremental e idempotente: reprocessar a mesma competência não duplica registros	M
RF-ING-07	Importar a tabela de municípios do IBGE (código, UF, coordenadas do centroide)	M
RF-ING-08	Registrar relatório de qualidade por carga (contagem, nulos, rejeições, tempo)	S
RF-ING-09	Detectar mudanças de esquema na fonte e falhar de forma explícita com alerta	S

5.2 Normalização e resolução de entidades (ENT)

ID	Requisito	Prior.
RF-ENT-01	Normalizar CNPJ (14 dígitos, validação de dígitos verificadores) e nomes	M
RF-ENT-02	Normalizar endereços e telefones para comparação	M

ID	Requisito	Prior.
RF-ENT-03	Resolver sócios pessoa física por nome normalizado + CPF mascarado, atribuindo nível de confiança	M
RF-ENT-04	Vincular fornecedores do PNCP aos cadastros da Receita por CNPJ	M
RF-ENT-05	Tratar sócios pessoa jurídica (cadeias societárias) com profundidade configurável	S

5.3 Análise (ANA)

ID	Requisito	Prior.
RF-ANA-01	Construir o grafo heterogêneo conforme 4.1, por órgão, município, UF ou período	M
RF-ANA-02	Calcular comunidades (Louvain/Leiden) e betweenness, com semente fixa	M
RF-ANA-03	Calcular o indicador RC por licitação com comparação a grafo nulo	M
RF-ANA-04	Executar o teste de Benford conforme 4.2, com regras de aplicabilidade e correção de múltiplas comparações	M
RF-ANA-05	Detectar fracionamento conforme 4.3 com janelas configuráveis	M
RF-ANA-06	Calcular indicadores de empresas recém-criadas conforme 4.4	M
RF-ANA-07	Calcular o IEA com decomposição por sinal, pesos versionados e confiança	M
RF-ANA-08	Disparar análises de forma assíncrona ao consultar órgão/município, informando progresso	M
RF-ANA-09	Permitir recálculo com outro conjunto de parâmetros sem perder resultados anteriores	S
RF-ANA-10	Cruzar preço adjudicado com preços de referência por item, quando disponíveis	C

5.4 Configuração (CFG)

ID	Requisito	Prior.
RF-CFG-01	Manter pesos, limiares e janelas em configuração versionada, com histórico de alterações e autor	M
RF-CFG-02	Manter tabela de tetos legais por modalidade/objeto com data de vigência inicial e final	M
RF-CFG-03	Permitir perfis de análise (conservador, padrão, exploratório)	S

5.5 API e backend (API)

ID	Requisito	Prior.
RF-API-01	Expor endpoints REST para órgãos, fornecedores, contratações, achados, grafos e IEA, documentados em OpenAPI 3.1	M
RF-API-02	Autenticação (OIDC/JWT) e autorização por papéis: ADMIN, AUDITOR, GESTOR, PUBLICO	M
RF-API-03	Paginação, filtros e ordenação padronizados; limites de taxa por perfil	M
RF-API-04	Persistir achados, evidências, parâmetros e execuções em PostgreSQL, com migrações Flyway	M
RF-API-05	Registrar trilha de auditoria imutável de acessos, exportações e alterações de parâmetros	M
RF-API-06	Endpoint de saúde e métricas operacionais (readiness/liveness)	S

5.6 Relatórios e exportação (REL)

ID	Requisito	Prior.
RF-REL-01	Gerar dossiê executivo em PDF por contratação, órgão ou fornecedor, com sumário, sinais, evidências e aviso metodológico	M

ID	Requisito	Prior.
RF-REL-02	Exportar achados e dados de apoio em CSV e Parquet	M
RF-REL-03	Incluir no dossiê a versão do modelo, pesos, competência da base e hashes das evidências	M
RF-REL-04	Permitir verificação independente: um comando/rota recebe o dossiê e confere os hashes	S
RF-REL-05	Oferecer canal de contestação/retificação para pessoas citadas e registrar o tratamento	S

5.7 Visualização (UI)

ID	Requisito	Prior.
RF-UI-01	Busca de órgão, município, fornecedor ou edital	M
RF-UI-02	Visualização de rede (Cytoscape.js) ao selecionar um edital: nós por tipo, arestas coloridas por tipo de vínculo (vermelho para sócio/endereço compartilhado), tamanho do nó por centralidade	M
RF-UI-03	Painel de detalhe com IEA, sinais, evidências e links para a fonte oficial	M
RF-UI-04	Filtros por período, UF, valor, modalidade, nível de risco	M
RF-UI-05	Linha do tempo de contratações por fornecedor e visualização das janelas de fracionamento	S
RF-UI-06	Mapa por município com distribuição de risco agregada (sem identificar pessoas físicas para o perfil PUBLICO)	C
RF-UI-07	Aviso metodológico visível em todas as telas que exibem níveis de risco	M

6. Requisitos não funcionais

ID	Categoria	Requisito
RNF-01	Desempenho	Importação completa do dump da Receita (~80 GB descompactados) em ⩽ 6 h em servidor de referência (16 vCPU, 64 GB RAM, NVMe)
RNF-02	Desempenho	Consulta de um órgão médio (⩽ 5.000 contratações/ano) com resultado do IEA em ⩽ 60 s na primeira execução e ⩽ 2 s em cache
RNF-03	Desempenho	Renderização de grafo com até 2.000 nós em ⩽ 3 s no navegador
RNF-04	Escalabilidade	Workers horizontalmente escaláveis; fila com reentrega e dead-letter queue
RNF-05	Disponibilidade	Meta de 99,5% para API e interface (excluída janela de manutenção)
RNF-06	Segurança	OWASP ASVS nível 2; TLS 1.2+; segredos fora do repositório; dependências com varredura (SCA) em CI
RNF-07	Privacidade	Minimização de dados; perfil PUBLICO sem identificação de pessoa física; registro de bases legais e RIPD (relatório de impacto)
RNF-08	Reprodutibilidade	Mesma entrada + mesma versão + mesmos parâmetros ⇒ mesma saída (bit a bit nas métricas)
RNF-09	Auditabilidade	Logs estruturados com correlação de requisição; trilha de auditoria com retenção ⩾ 5 anos
RNF-10	Manutenibilidade	Cobertura de testes ⩾ 80% em backend e analytics; análise estática sem falhas críticas
RNF-11	Observabilidade	Métricas (Prometheus), traces (OpenTelemetry) e painéis (Grafana) para ingestão, filas e API
RNF-12	Usabilidade e acessibilidade	Conformidade com WCAG 2.1 AA; interface em português do Brasil
RNF-13	Portabilidade	Execução por Docker Compose (desenvolvimento) e Kubernetes/Helm (produção)

ID	Categoria	Requisito
RNF-14	Licenciamento	Código sob licença aberta definida pelo autor; dependências compatíveis; dados mantêm licenças de origem
RNF-15	Respeito à fonte	Coleta no PNCP respeita limites de taxa, cache e janela de menor carga, sem degradar o serviço oficial

7. Arquitetura e tecnologias

7.1 Visão em camadas

```
NexusGov/
├── backend/     Java 21, Spring Boot 3.4, Spring Security, Flyway
├── ingestion/   Python 3.12, DuckDB, RabbitMQ
├── analytics/   NetworkX/igraph, SciPy, Polars/DuckDB
├── frontend/    React 18, Vite, Tailwind, Cytoscape.js
├── spec/        Matriz de requisitos SDD
├── infra/       Docker, Compose, Helm, CI/CD
└── docs/        Metodologia, RIPD, manuais
```

Fluxo: PNCP/Receita/IBGE → **ingestão** (payload bruto + Parquet) → **mensageria** (RabbitMQ) → **analytics** (grafo, Benford, fracionamento) → **backend** (persistência em PostgreSQL, API, relatórios) → **frontend**.

7.2 Stack por componente

Camada	Tecnologia	Justificativa
Backend	Java 21, Spring Boot 3.4, Spring Security (OIDC/JWT, RBAC), Spring Data JPA, springdoc-openapi	Maturidade corporativa, segurança, virtual threads
Migrações	Flyway	Versionamento determinístico do esquema
Banco transacional	PostgreSQL 16 (com PostGIS opcional e extensão pg_trgm para similaridade de texto)	Achados, evidências, parâmetros, auditoria

Camada	Tecnologia	Justificativa
Ingestão	Python 3.12, DuckDB, PyArrow, httpx (assíncrono), tenacity (retentativas)	Processamento colunar de dezenas de GB em máquina única
Armazenamento analítico	Parquet particionado (competência/UF) em disco/S3 compatível (MinIO)	Compressão e leitura seletiva
Mensageria	RabbitMQ (filas duráveis, DLQ, confirmação de entrega)	Tarefas assíncronas e reprocessamento
Analytics	Polars/DuckDB, NetworkX e python-igraph (Louvain/Leiden), SciPy/statsmodels (testes estatísticos), scikit-learn (DBSCAN)	Rigor estatístico e desempenho em grafos
Relatórios PDF	OpenPDF ou Apache PDFBox/JasperReports no backend	PDF determinístico e paginado
Frontend	React 18, TypeScript, Vite, Tailwind CSS, Cytoscape.js (alternativa: React Flow), TanStack Query	Visualização de redes e UX responsiva
Testes	JUnit 5, Testcontainers, pytest, Hypothesis, Vitest, Playwright	Pirâmide de testes completa
Qualidade	SonarQube, Ruff, mypy, ESLint, Checkstyle, OWASP Dependency-Check	Padrão contínuo
Observabilidade	OpenTelemetry, Prometheus, Grafana, Loki	Operação e depuração
CI/CD	GitHub Actions, Docker, Helm, Trivy	Entrega reproduzível e segura
Orquestração de lotes	Cron/Kubernetes CronJob ou Dagster (opcional)	Agendamento mensal de cargas

7.3 Decisões arquiteturais registradas (ADR) a produzir

1. Fronteira entre backend Java e analytics Python (contrato por mensagens e tabelas, evitando acoplamento por chamadas síncronas).
2. Estratégia de identidade de sócios (confiança e homonímia).

3. Escolha Louvain vs. Leiden.
4. Política de retenção e anonimização para o perfil público.
5. Estratégia de versionamento de pesos e parâmetros.

7.4 Modelo de dados (entidades principais)

`orgao`, `fornecedor`, `socio` (com `confianca_identidade`), `vinculo_societario`, `contratacao`, `item_contratacao`, `participacao_licitacao`, `evidencia` (com `hash_sha256`, `url_fonte`, `coletado_em`), `achado` (eixo, sinal, escore, confiança), `iea_resultado` (nível, versão de parâmetros), `parametro_versao`, `teto_legal_vigencia`, `execucao_analise`, `trilha_auditoria`, `contestacao`.

8. Processo de desenvolvimento (SDD)

1. **Especificação primeiro:** cada requisito deste documento vira arquivo em `spec/` com ID, critérios de aceite em formato Given/When/Then e vínculos com testes.
2. **Matriz de rastreabilidade:** requisito → teste → commit → evidência de execução, validada em CI (falha se requisito Must sem teste).
3. **Ciclo:** iterações de 2 semanas; definição de pronto inclui testes, documentação da especificação, revisão de segurança e atualização da matriz.
4. **Controle de mudanças:** alteração de métrica, peso ou limiar exige ADR e novo número de versão do modelo.
5. **Ramificação:** trunk-based com revisão obrigatória de pull request e commits convencionais.

8.1 Roadmap sugerido

Fase	Entregas	Duração estimada
0 — Fundação	Repositório, CI/CD, `spec/`, RIPD preliminar, ADRs	2 semanas
1 — Ingestão	PNCP + Receita + IBGE em Parquet, relatório de qualidade	4 a 5 semanas
2 — Resolução de entidades e grafo	Normalização, confiança de vínculos, Louvain/Leiden, RC	4 semanas
3 — Estatística	Benford, fracionamento, pop-up vendors, IEA	4 semanas

Fase	Entregas	Duração estimada
4 — Backend e segurança	API, RBAC, persistência, trilha de auditoria, PDF	4 semanas
5 — Frontend	Busca, grafo interativo, painéis, acessibilidade	4 semanas
6 — Validação	Dados sintéticos, casos de referência, ajuste de limiares, documentação científica	3 semanas
7 — Piloto	Um município/estado, coleta de feedback, parecer jurídico	3 semanas

9. Estratégia de testes

- **Unitários:** funções estatísticas contra valores conhecidos da literatura (ex.: conjunto sintético perfeitamente Benford deve ter MAD ≈ 0).
- **Propriedades (Hypothesis):** invariância do IEA a reordenação de entradas; monotonicidade dos sinais.
- **Integração:** Testcontainers com PostgreSQL e RabbitMQ; contratos de API validados contra OpenAPI.
- **Ponta a ponta:** Playwright cobrindo busca → grafo → dossiê PDF.
- **Desempenho:** testes de carga da API e benchmark de importação em dataset completo.
- **Segurança:** SAST, SCA, DAST (OWASP ZAP) e testes de autorização por papel.
- **Qualidade estatística:** métricas de precisão/revocação em dados sintéticos e análise de sensibilidade.

10. Critérios de aceite

10.1 Aceite por funcionalidade (Given/When/Then)

CA-ING-01 — Idempotência de carga

- Dado que a competência 2026-09 da Receita já foi importada,
- Quando a importação é executada novamente,
- Então a contagem de registros permanece idêntica e o relatório de qualidade indica 0 inserções novas.

CA-ING-02 — Evidência imutável

- Dado um payload coletado do PNCP,
- Quando o registro é salvo,
- Então existe hash SHA-256 correspondente ao conteúdo bruto, e qualquer alteração posterior do payload invalida a verificação (RF-REL-04).

CA-ENT-01 — Confiança de vínculo

- Dados dois sócios com mesmo nome e CPF mascarado idêntico,
- Quando a resolução de entidades é executada,
- Então o vínculo é criado com confiança < 1,0 e rotulado "identidade presumida" na API e na UI.

CA-ANA-01 — Detecção de cartel sintético

- Dado um conjunto sintético com 5 empresas compartilhando 2 sócios e disputando 20 licitações,
- Quando o grafo é analisado,
- Então as 5 empresas pertencem à mesma comunidade e o RC das 20 licitações supera o limiar "Médio" (revocação ⩾ 90% no conjunto de validação).

CA-ANA-02 — Benford aplicável e não aplicável

- Dado um conjunto com 150 valores,
- Quando o teste é solicitado,
- Então o resultado é "não aplicável (n < 300)" e não é gerado achado.
- Dado um conjunto com 5.000 valores gerados conforme Benford,
- Então MAD ⩽ 0,006 e nenhum achado é gerado.

CA-ANA-03 — Fracionamento

- Dado um fornecedor com 4 dispensas de mesmo CATMAT em 45 dias, cada uma a 95% do teto vigente,
- Quando a análise 30-90 dias é executada,
- Então um achado de fracionamento é gerado com as 4 contratações listadas e o teto vigente na data de cada uma.

CA-ANA-04 — Tetos com vigência

- Dado que o teto muda de valor em uma data X,
- Quando contratações anteriores e posteriores a X são avaliadas,
- Então cada uma é comparada ao teto vigente em sua data, sem alteração de código.

CA-ANA-05 — Determinismo

- Dados os mesmos insumos, a mesma versão de código e parâmetros,
- Quando a análise é executada duas vezes,
- Então o IEA, os níveis e a composição dos sinais são idênticos.

CA-SG-01 — Salvaguarda de linguagem

- Dado qualquer tela, relatório ou resposta de API,
- Quando o conteúdo é varrido por teste automatizado,
- Então não contém termos proibidos (lista configurável: fraude, crime, culpado, conluio comprovado, etc.) e contém o aviso metodológico.

CA-SG-02 — Elevado exige dois eixos

- Dado um caso com apenas um sinal alto (ex.: só Benford),
- Quando o IEA é calculado,
- Então o nível máximo é "Médio".

CA-API-01 — Autorização

- Dado um usuário com papel PUBLICO,
- Quando solicita dados de pessoa física identificada,
- Então a API responde com dados agregados/mascarados e registra o acesso na trilha de auditoria.

CA-REL-01 — Dossiê verificável

- Dada uma contratação com IEA "Elevado",
- Quando o dossiê PDF é gerado,
- Então ele contém: sinais, evidências, URLs oficiais, hashes, competência da base, versão dos pesos e aviso metodológico, e a verificação dos hashes retorna sucesso.

CA-UI-01 — Visualização de rede

- Dado um edital com 8 licitantes, dois deles com sócio comum,
- Quando o usuário abre o edital,
- Então o grafo exibe os 8 nós, uma aresta vermelha entre as empresas com sócio comum, e painel lateral com a evidência, em até 3 s.

CA-UI-02 — Acessibilidade

- Quando a auditoria automatizada (axe) é executada nas telas principais,
- Então não há violações de nível crítico ou sério e a navegação por teclado cobre os fluxos principais.

10.2 Aceite não funcional

ID	Critério de aceite
CA-RNF-01	Benchmark de importação completa atende RNF-01 em ambiente de referência documentado
CA-RNF-02	Teste de carga: p95 da API ⩽ 800 ms com 100 usuários simultâneos
CA-RNF-03	Varredura SCA/SAST sem vulnerabilidades críticas ou altas em aberto
CA-RNF-04	Cobertura de testes ⩾ 80% e matriz de rastreabilidade com 100% dos requisitos Must cobertos
CA-RNF-05	RIPD aprovado e parecer jurídico anexado antes da publicação com dados de pessoas físicas

10.3 Aceite científico

ID	Critério
CA-CIE-01	Relatório metodológico publicado com fórmulas, parâmetros, limitações e referências (Newcomb, Benford, Nigrini, Blondel et al. [Louvain], Traag et al. [Leiden])
CA-CIE-02	No conjunto sintético de validação: precisão ⩾ 80% e revocação ⩾ 85% para cartel e fracionamento no nível "Médio" ou superior
CA-CIE-03	Análise de sensibilidade demonstra que variações de ±20% nos pesos não alteram o nível em mais de 10% dos casos
CA-CIE-04	Experimentos reprodutíveis a partir de um único comando e de dataset versionado

11. Riscos e mitigação

Risco	Impacto	Mitigação
Falsos positivos por homonímia/sobrenome	Dano reputacional a pessoas	Confiança de vínculo, regras SG-04/SG-05, canal de contestação
Interpretação do IEA como acusação	Dano jurídico	Linguagem controlada, aviso metodológico, perfil PUBLICO agregado
Mudança de esquema/limites na API do PNCP	Quebra da ingestão	Testes de contrato, detecção de esquema, cache e backoff
Qualidade/completude dos dados do PNCP	Sinais incorretos	Relatórios de qualidade, confiança c_i no IEA
Benford inadequado para valores tabelados	Alertas espúrios	Regras de aplicabilidade e exclusão por catálogo
Volume de dados	Lentidão	DuckDB/Parquet, particionamento, amostragem em betweenness
Mudança de tetos legais	Detecção errada de fracionamento	Tabela de vigência (RF-CFG-02)
Conformidade LGPD	Sanções e retirada do ar	RIPD, minimização, parecer jurídico prévio

12. Entregáveis

1. Código-fonte nos cinco módulos e infraestrutura como código.
2. Diretório `spec/` com matriz de rastreabilidade.
3. Documentação OpenAPI, manual do auditor e manual de operação.
4. Relatório metodológico-científico (base para registro de software e produção no Lattes).
5. RIPD e política de privacidade.
6. Dados sintéticos e scripts de validação reproduzíveis.
7. Pipeline de CI/CD e imagens de contêiner versionadas.

13. Pontos em aberto para validação

- Definição do licenciamento (ex.: AGPL-3.0 para garantir abertura em serviços derivados).
- Escopo geográfico do piloto (município, estado ou nacional).
- Política de exposição de nomes de pessoas físicas no perfil público.
- Disponibilidade de preços de referência (ex.: bases de preços públicas) para o RF-ANA-10.
- Infraestrutura de hospedagem (nuvem, universidade ou órgão parceiro).

Observação: os valores numéricos de limiares, pesos e metas de desempenho deste documento são pontos de partida a calibrar na fase de validação; os tetos legais de dispensa devem ser preenchidos pela tabela de parâmetros com base na legislação e nos decretos de atualização vigentes.